



ZAP Scanning Report

Site: <http://localhost:8080>

Generated on Fri, 1 May 2026 20:52:34

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	1
Low	1
Informational	2
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	http://localhost:8080	Percentage of responses with status code 3xx	12 %
Info	Informational	http://localhost:8080	Percentage of responses with status code 4xx	87 %
Info	Informational	http://localhost:8080	Percentage of endpoints with content type text/html	66 %
Info	Informational	http://localhost:8080	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost:8080	Count of total endpoints	6

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	4
Permissions Policy Header Not Set	Low	4
Non-Storable Content	Informational	3
Storable and Cacheable Content	Informational	4

Alert Detail**Medium****Content Security Policy (CSP) Header Not Set****Description**

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

URL<http://localhost:8080/>Node
Name

http://localhost:8080/

Method

GET

Parameter

Attack

Evidence

Other Info

URL<http://localhost:8080/oficina>Node
Name

http://localhost:8080/oficina

Method

GET

Parameter

Attack

Evidence

Other Info

URL<http://localhost:8080/robots.txt>Node
Name

http://localhost:8080/robots.txt

Method

GET

Parameter

Attack

Evidence

Other Info

URL<http://localhost:8080/sitemap.xml>Node
Name

http://localhost:8080/sitemap.xml

Method

GET

Parameter

Attack

Evidence

Other Info

Instances

4

Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header. https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
Reference	
CWE Id	693
WASC Id	15
Plugin Id	10038
Low	Permissions Policy Header Not Set
Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.
URL	http://localhost:8080/
Node Name	http://localhost:8080/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:8080/oficina
Node Name	http://localhost:8080/oficina
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:8080/robots.txt
Node Name	http://localhost:8080/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:8080/sitemap.xml

Node Name	http://localhost:8080/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063
Informational	Non-Storable Content
Description	The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.
URL	http://localhost:8080/oficina/v1
Node Name	http://localhost:8080/oficina/v1
Method	GET
Parameter	
Attack	
Evidence	302
Other Info	
URL	http://localhost:8080/oficina/v1
Node Name	http://localhost:8080/oficina/v1
Method	GET
Parameter	
Attack	
Evidence	no-store
Other Info	
URL	http://localhost:8080/oficina/v1/
Node Name	http://localhost:8080/oficina/v1/
Method	GET
Parameter	

Attack	
Evidence	no-store
Other Info	
Instances	3
	The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).
Solution	
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049
Informational	Storable and Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	http://localhost:8080/
Node Name	http://localhost:8080/
Method	GET
Parameter	

Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://localhost:8080/oficina
Node Name	http://localhost:8080/oficina
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://localhost:8080/robots.txt
Node Name	http://localhost:8080/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://localhost:8080/sitemap.xml
Node Name	http://localhost:8080/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
Instances	4
	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private
Solution	Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html

CWE Id	524
WASC Id	13
Plugin Id	10049

Sequence Details

With the associated active scan results.